

Indirect Prompt Injection

Author: Moe Htet Ar Kar (Phoe Cho)

1. Vulnerability Concept & Mechanics

Indirect prompt injection occurs when an LLM processes untrusted data retrieved from external or third-party sources, such as web pages, user reviews, support tickets, documents, or emails. If the external data contains malicious instructions, the LLM may interpret those instructions as trusted directives and deviate from the user's original intent.

2. Attack Vector & Exploitation Methodology

Vector Placement

Identify external data sources that the AI agent is designed to ingest, retrieve, summarize, or process, and assess whether attacker-controlled content can be introduced into those sources.

Execution Trigger

Cause the AI agent to process the contaminated content through a normal user workflow, such as retrieval, summarization, or question answering.

Payload Execution

Determine whether injected instructions influence the agent's subsequent behavior or cause unauthorized tool calls or actions.

Attack Stage	Component	Action
1. Ingestion	External Data Source	Attacker-controlled instructions are embedded in external content.
2. Processing	AI Agent	The agent reads the untrusted content during retrieval or processing.
3. Execution	Model & APIs	The model incorrectly interprets data as instructions and may initiate unauthorized actions.

3. Validation & Impact

- Impact:** Potential unauthorized data access, manipulation of automated workflows, unintended tool invocation, and data exfiltration.
- Validation:** Verify whether external untrusted content can influence the agent to perform actions outside the user's explicit request.

4. Remediation & Hardening

- Treat all externally retrieved content as untrusted input.
- Clearly separate data from executable instructions within the AI processing pipeline.
- Implement content inspection and policy enforcement before untrusted data reaches privileged agentic components.
- Enforce strict execution boundaries so that data-derived text cannot directly trigger privileged system commands or API operations.